

1-07-2023 έγγραφο, στο οποίο ανέφερε ότι οι ενέργειες που είχαν πραγματοποιηθεί ήταν επαρκείς και ότι η ευπάθεια είχε πλέον αποκατασταθεί.

Η Αρχή, ωστόσο, διαπίστωσε ότι η επαναλαμβανόμενη φύση του περιστατικού παραβίασης δεδομένων υποδεικνύει σοβαρές ελλείψεις στα μέτρα ασφαλείας που είχε λάβει ο υπεύθυνος επεξεργασίας. Συγκεκριμένα, η Αρχή εξέτασε την κατάσταση και κατέληξε ότι η μη εξουσιοδοτημένη πρόσβαση σε προσωπικά δεδομένα πολιτών του Δήμου Αλίμου, η οποία είχε συμβεί σε δύο διαφορετικές περιπτώσεις, συνιστά σοβαρή παραβίαση του άρθρου 32 του ΓΚΠΔ, το οποίο απαιτεί από τους υπευθύνους επεξεργασίας να εφαρμόζουν κατάλληλα τεχνικά και οργανωτικά μέτρα για την ασφάλεια των δεδομένων.

2. ΑΠΟΦΑΣΙΖΕΙ

1. Διαπιστώνει ότι ο υπεύθυνος επεξεργασίας παραβίασε το άρθρο 32 του ΓΚΠΔ, καθώς δεν είχε λάβει τα κατάλληλα μέτρα ασφαλείας για την προστασία των προσωπικών δεδομένων.
2. Επιβάλλει στον υπεύθυνο επεξεργασίας διοικητικό πρόστιμο ύψους 50.000 ευρώ, το οποίο θα πρέπει να καταβληθεί εντός 30 ημερών από την κοινοποίηση της παρούσας απόφασης.
3. Διατάσσει τον υπεύθυνο επεξεργασίας να προβεί σε άμεσες ενέργειες για την ενίσχυση των μέτρων ασφαλείας και την αποφυγή παρόμοιων περιστατικών στο μέλλον.
4. Ενημερώνει τον καταγγέλλοντα για την απόφαση αυτή και τις ενέργειες που θα αναληφθούν από τον υπεύθυνο επεξεργασίας.

Η παρούσα απόφαση είναι οριστική και εκτελεστή.

Αθήνα, 5 Ιουλίου 2024

Ο Πρόεδρος της Αρχής Προστασίας Δεδομένων Προσωπικού Χαρακτήρα
Κωνσταντίνος Μενουδάκος

3

Document 07-2023 which includes the following:

- The application in which the vulnerability was identified is hosted at the electronic address (url) "...", while access to the files of the citizens of the Municipality of Alimos is made through the electronic address (url) "...". Due to the upgrade of the application to a new version of the software, which had been put into trial operation in the production environment, a security gap was created that caused the incident in question.
- As can be seen from the access log of the Municipality of Alimos files ("..."), increased access to the files of the Municipality of Alimos was detected from two specific IP addresses¹, at which point the application was shut down.
- Through a check of the above access log, it was found that access was gained to 1200 files out of a total of 45000 available in the application.
- A total of approximately 3800 unauthorized access attempts were made, most of which were unsuccessful or concerned the same file.
- The vulnerability existed from 12-06-2023 when the trial operation of the new version of the application was implemented until 21-06-2023, the day of the notification of the data breach incident.
- After various technical implementations to make the application functional and secure, the data controller ultimately decided to use tokens. Through this process, a user must either own the file and therefore have uploaded it themselves to the application, or be a user of the application on behalf of the Municipality of Alimos to gain access or download a file. Through the token, which is verified by the application, user identification and role verification are performed.

¹ One of the two IP addresses that appears to have gained extensive unauthorized access to the files of the citizens of the Municipality of Alimos corresponds to a computer used by an auditor of the Authority in the context of investigating the above complaint.

4

- No notification of the data breach incident was made to the affected individuals, taking into account

the following criteria:

- o The application was in trial operation after the upgrade.
- o The time period during which the vulnerability was identified was short.
- o The number of files affected was small.
- o The data of the files hosted in the specific application is considered to be of a simple nature.
- o Immediate corrective measures were taken.
- o The risks arising from this specific breach incident are characterized as low.

Additionally, the data controller submitted a contract between themselves and the processor, in Article 11 of which reference is made to the obligations of the contracting parties in order to comply with the applicable legislation and relevant decisions of the Personal Data Protection Authority regarding the protection of personal data, while Article 5 states that the processor takes appropriate measures to safeguard the confidentiality of information that has been designated as such.

Subsequently, the Authority, after examining the above response, requested with document no. Γ/ΕΞΕ/1783/13-07-2023 additional clarifications and a more detailed description regarding the security gap that was created, the manner in which the above security incident occurred, the monitoring of the latest version of the application during the relevant trial period, the policy generally followed for ensuring changes occurring in information systems, the reason for the reoperation of the application (which was indicated by the complainant in their second document) without the necessary measures being taken for the protection of personal data, as well as a description of the investigation process of the said breach incident. Furthermore, the Authority, with the aforementioned document, requested clarifications regarding the issue of accesses that were characterized as unauthorized, whether the suspension of the use of the application raises issues of availability of files and related services to citizens, and finally, whether and how the subjects are affected.

5

data from the aforementioned breach incident and therefore whether they should be notified.

Additionally, the Authority, with its letter No. Γ/ΕΞΕ/1785/13-07-2023, requested clarifications from the data processor regarding the policy followed in cases of upgrading existing software, in what environment the changes take place, whether the specific security gap affects other data controllers to whom the processor provides similar services, and what actions it will take in case of an affirmative response.

Subsequently, with its letter No. Γ/ΕΙΣ/5330/19-07-2023, the complainant informed the Authority again that the files of the Municipality of Alimos were once again easily accessible by unauthorized users in exactly the same manner (as the Authority also found). Following this, the Authority issued Decision No. 28/2023 (Single-Member Body), whereby it imposed a temporary order for the data controller to take all necessary actions to restrict the free access of internet users to the files of the data controller's application and that the files containing personal data of users of the application should only be available to appropriately authorized users or to the data subjects themselves, without being easily accessible by other unauthorized users. As determined by the Authority, after the issuance of the temporary order, the data controller disabled the ability for unauthorized access to personal data (the relevant websites were deactivated).

Thereafter, the data controller responded with its letter No. Γ/ΕΙΣ/5840/10-08-2023 to some of the clarifications requested by the Authority in the aforementioned letter as follows:

- The security gap was created by the activation of the incorrect version of the application, which is due to the internal configuration management processes of the data processor. Specifically, the code of the previous version was retained with elements of the newer software that was developed.
- The interruption of the application's operation affected only the electronic services and not the issuance of the files hosted by the application through requests with the physical presence of the citizens.

6

• Regarding the other clarifications, the data controller awaited assistance from the data processor. Subsequently, after the passage of more than a month, during which there was no further response to the Authority, the Authority sent letters No. Γ/ΕΞΕ/2378/21-09-2023 and No. Γ/ΕΞΕ/2379/21-09-2023 to remind the data controller and the data processor, respectively. Following this, the data processor

responded with its letter No. Γ/ΕΙΣ/6731/25-09-2023, in which the following was stated:

- There is no documented change management policy for the software developed by the company.
- In cases of changes, the following informal steps are followed:
 - ο Informing the client about the interruption of the application's operation (usually during non-productive hours)
 - ο Stopping the operation of the application
 - ο Installing the new version of the application
 - ο Operating the new application
 - ο Checking for correct operation
- Testing of the changes is usually conducted on internal servers, while in more complex cases related to security issues, these are conducted directly in the production environment.
- Most applications developed by the company are later and more secure than the application used by the data controller for the application and issuance of digital certificates. This specific application additionally operates in the Municipality of Keratsini and in the Municipality of Voula – Vari – Vouliagmeni. The software upgrade does not appear to have affected these data controllers. Furthermore, the storage space of the files and the application settings are different in each case. The data processor continues to conduct tests to ensure that the aforementioned municipalities have not been affected.

Finally, the data controller responded with its letter No. Γ/ΕΙΣ/6875/02-10-2023, providing additional clarifications regarding the volume of

7

of files to which unauthorized access was obtained and from which internet addresses this occurred. The data controller also reiterates that the relevant functionality, which ultimately allowed unauthorized access to data, was activated for testing purposes conducted as part of the application upgrade, while also noting that any user examining the source code of the application's website could infer how to gain unauthorized access to the data. Furthermore, it was found that as a result of the breach incident, files of the data controller were exposed, such as police identity records that can easily be used in identity theft incidents in online environments. Finally, the data controller reiterates the claims made in its letter with reference number Γ/ΕΙΣ/5144/12-07-2023 regarding the technical solution adopted to address the relevant vulnerability, as well as that despite continuous inquiries to the data processor, not all clarifications regarding the incident had been received by the time of sending the above document.

It is also noted that all responses from the data controller to the Authority, as described above, were submitted by the Data Protection Officer (DPO) of the Municipality. In the last document, it is also stated that the DPO advised the data controller to notify the affected data subjects of the incident.

Following the examination of the case file, the Authority sent letters with reference numbers Γ/ΕΞΕ/2554/12-10-2023 and Γ/ΕΞΕ/2553/12-10-2023 to the data controller and the data processor respectively, in order to discuss the case before the Plenary of the Authority on Tuesday, October 24, 2023. In this meeting, which was held via videoconference, the following were present on behalf of the data controller: B, Secretary General of the Municipality, Maria Marioli, lawyer with registration number ..., Mayor's Advisor, on behalf of the company KaPa Data Consulting, which performs the duties of DPO for the data controller, Konstantina Ithakisiou, lawyer, with registration number ..., and

G, an external associate of the company, and on behalf of the data processor, the legal representatives of the companies D and E, in order to provide clarifications on the case in question. After the meeting, the data controller and the data processor were given a deadline to submit a memorandum. Subsequently, the data controller submitted, within the set deadline, the memorandum with reference number Γ/ΕΙΣ/7936/07-11-2023, along with the supplementary documents with reference numbers Γ/ΕΙΣ/7983/09-11-2023 and Γ/ΕΙΣ/8105/14-11-2023. In its memorandum, the data controller essentially reiterated the claims it had previously made before the Authority. Specifically, the memorandum states that a contract was concluded on 12-09-2022 between the data controller and the data processor for the maintenance of the online digital platform concerning the management of digital certificates for the citizens and businesses of the data controller, taking appropriate technical measures to safeguard the confidentiality of the information. It is further stated that upon discovering the unauthorized access to the files of the data controller, an investigation into the incident was immediately initiated. Following inadequate tests for the reoperation of the application, an order was given to suspend the operation of the application, which ultimately resumed on 03-11-2023 (i.e., after the hearing of the data controller before the Authority), after the necessary checks and corrections by the data processor had been completed. Additionally, in the same memorandum, the data controller states that the data processor provided him with the audit data concerning all the data subjects who were affected by the data breach incident, with the aim of informing them on a personal level rather than through a general notification/announcement, prioritizing data subjects for whom there was unauthorized access to police identity or passport data. Specifically, the data controller sent an email to the affected individuals informing them about the incident – while the template of such an informative letter was subsequently submitted to the Authority with the document with reference number Γ/ΕΙΣ/7983/09-11-2023. As indicated in this document, the data controller informed the data subjects about a cyberattack incident and a breach of the security of the Municipality's information systems by unauthorized users during which

9

An attempt was made to mass extract random files, among which there were files containing personal data. The above update also includes information that the data controller has taken the necessary actions to rectify the aforementioned incident, as well as that it has informed the Authority. Furthermore, according to the document with reference number Γ/ΕΙΣ/8105/14-11-2023, the unauthorized access to files concerned approximately nine hundred (900) data subjects – users of the services of the data controller. Of the aforementioned files, 150 pertained to identities or passports of a total of 148 subjects, who were informed by a letter sent via email on 03-11-2023 by the data controller. Finally, the document states that the process of informing the remaining affected subjects is ongoing.

The processor did not submit a special memorandum following its hearing. It is noted, however, that in the aforementioned memorandum with reference number Γ/ΕΙΣ/7936/07-11-2023 from the data controller, the changes to the software that took place by the processor on the platform to ensure and safeguard the data so that it is not possible for a user to "download" files of another person are described.

The Authority, after examining the details of the file and what emerged from the hearing before it and the memorandum of the data controller, along with its supplementary documents, having heard the rapporteur and the clarifications from the assistant rapporteurs, who attended without voting rights, after thorough discussion,

CONSIDERED IN ACCORDANCE WITH THE LAW

1. From the provisions of Articles 51 and 55 of the GDPR and Article 9 of Law 4624/2019 (Government Gazette A' 137), it follows that the Authority has the competence to supervise the application of the provisions of the GDPR, this law, and other regulations concerning the protection of individuals from the processing of personal data.
2. According to point 12 of Article 4 of the GDPR, "personal data breach: a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data which has been transmitted, stored, or otherwise processed."
3. According to Article 5(1)(f) of the GDPR, "personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."
4. According to the definitions in Article 24 of the GDPR: "1. Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and to be able to demonstrate that the processing is performed in accordance with this Regulation. Such measures shall be reviewed and updated when necessary. 2. Where appropriate in relation to the processing activities, the measures referred to in paragraph 1 shall include the implementation of appropriate policies for the protection of data by the data controller."
5. According to the definitions in Article 25 of the GDPR: "1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons from the processing, the data controller shall effectively implement, both at the time of determining the means of processing and at the time of the processing, appropriate technical and organizational measures, such as pseudonymization, designed to implement the data protection principles, such as data minimization, and to integrate the necessary safeguards into the processing in such a way as to meet the requirements of this Regulation and to...

11

The rights of data subjects are protected.

6. According to the definitions of Article 28 of the GDPR: "1. When processing is to be carried out on behalf of a controller, the processor shall only engage processors providing sufficient guarantees to implement appropriate technical and organizational measures in such a manner that processing will meet the requirements of this Regulation and ensure the protection of the rights of the data subject. 2. (...) 3. Processing by a processor shall be governed by a contract or other legal act under Union or Member State law, which binds the processor to the controller and sets out the subject matter and duration of the processing, the nature and purpose of the processing, the type of personal data and categories of data subjects, and the obligations and rights of the controller. The said contract or other legal act shall specify, in particular, that the processor: (...) c) takes all necessary measures pursuant to Article 32 (...) f) assists the controller in ensuring compliance with the obligations arising from Articles 32 to 36, taking into account the nature of the processing and the information available to the processor (...), g) makes available to the controller all information necessary to demonstrate compliance with the obligations set out in this Article and allows for and facilitates audits, including inspections, conducted by the controller or another auditor mandated by the controller.
7. According to the definitions of Article 31 of the GDPR: "The controller and the processor and, where applicable, their representatives shall cooperate, on request, with the supervisory authority in the performance of its tasks."
8. According to the definitions of Article 32 of the GDPR: "1. Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of the processing, as well as

the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, among others, as appropriate: a) the pseudonymization and encryption of personal data, b) the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems and services, c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, d) a process for regularly testing, assessing and evaluating the effectiveness of technical and organizational measures for ensuring the security of processing. 2. In assessing the appropriate level of security, account shall be taken in particular of the risks that are presented by the processing, in particular from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored or otherwise processed. 3. (...) 4. The controller and the processor shall take measures to ensure that any natural person acting under the authority of the controller or the processor who has access to personal data processes them only on instructions from the controller, unless he or she is required to do so by Union or Member State law.”

9. According to the definitions of Article 33 of the GDPR: “1. In the event of a personal data breach, the controller shall notify the supervisory authority without undue delay and, where feasible, not later than 72 hours after having become aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. When the notification to the supervisory authority is not made within 72 hours, it shall be accompanied by reasons for the delay. 2. The processor shall notify the controller without undue delay after becoming aware of a personal data breach.”

13

personal data. 3. The notification referred to in paragraph 1 shall at a minimum: a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects affected, as well as the categories and approximate number of personal data records affected, b) announce the name and contact details of the data protection officer or another contact point from which more information can be obtained, c) describe the potential consequences of the personal data breach, d) describe the measures taken or proposed by the data controller to address the personal data breach, as well as, where appropriate, measures to mitigate any potential adverse effects. 4. In cases where it is not possible to provide the information simultaneously, it may be provided gradually without undue delay. 5. The data controller documents each personal data breach, consisting of the facts relating to the personal data breach, its effects, and the remedial measures taken. This documentation enables the supervisory authority to verify compliance with the present article.

10. According to the definitions in Article 34 of the GDPR: “1. When a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall notify the personal data breach without undue delay to the data subject. 2. The notification to the data subject referred to in paragraph 1 of this article shall describe in clear and plain language the nature of the personal data breach and shall contain at least the information and measures referred to in Article 33(3)(b), (c), and (d). 3. The notification to the data subject referred to in paragraph 1 is not required if any of the following conditions are met: a) the data controller has implemented appropriate technical and organizational protection measures, and those measures were applied to the personal data affected by the breach, in particular measures that render the personal data unintelligible to those not authorized to access it, such as encryption, b) the data controller has subsequently taken measures that ensure that the high risk to the rights and freedoms of data subjects referred to in paragraph 1 is no longer likely to materialize, c) it would involve disproportionate effort. In such cases, a public communication or a similar measure may be used to inform data subjects in an equally effective manner. 4. If the data controller has not already notified the personal data breach to the data subject, the supervisory authority may, after assessing the likelihood of a high risk resulting from the personal data breach, require it to do so or may decide that any of the conditions referred to in paragraph 3 are met.”

11. In this case, from the evidence in the case file, it appears that for this processing, adequate security measures were not taken from the outset by design in relation to the corresponding risks to the rights and freedoms of natural persons, nor were there procedures in place to monitor the

effectiveness of the existing security measures. Specifically:

- Appropriate technical and organizational measures had not been implemented to ensure the confidentiality of the personal data affected by the said personal data breach, which concern requests from citizens to the data controller on various issues. As indicated by the description of the breach incident, unauthorized users could gain or had gained access to personal data of citizens of the data controller, which included, among other things, copies of police identification cards, responsible declarations of natural persons with completed...

15

all fields with personal data requested by the responsible declaration form (such as first names, patronymics, maternal names, date of birth, postal/electronic address, tax identification number, etc.), driving licenses, etc. As also emerges from the history of the present case, unauthorized access was quite easy, as any user with basic technical knowledge of website creation could easily "recognize" that this specific vulnerability exists.

- There do not appear to have been sufficient control points to timely detect such violations of personal data, such as regular monitoring, evaluation, and assessment of the records where accesses to files containing personal data of citizens of the specific application (logs) are recorded, in order to detect non-"suspicious" behaviors (i.e., actions by users that could be interpreted as unauthorized accesses or attempts at unauthorized accesses). This is also confirmed by the fact that the personal data breach was not detected by the data controller, nor by the data processor, until the former was informed by the Authority following a complaint. This indeed occurred on three (3) different occasions when the relevant vulnerability was present, and thus, a corresponding data breach incident took place.
- The same data breach incident occurred three (3) times, with each activation of a new version of the application. Therefore, there was no immediate effective response to the incident. Specifically, the response was temporary, as it consisted of the complete deactivation of the relevant website, which did not allow the citizens of the data controller to utilize this online service: however, each new activation of the website continued to carry the same vulnerability – and this happened, as previously mentioned, on two other occasions. Furthermore, it appears that effective change management mechanisms were not in place, nor mechanisms for identifying security gaps that lead to data breach incidents.

12. The data controller does not have effective procedures for monitoring and evaluating the data processor. Firstly, the contract between the controller and the processor does not comprehensively cover the obligations of the processor towards the controller regarding access to and processing of the personal data maintained in the application, as prescribed in Article 28 of the GDPR, since the contract only contains a general reference to compliance with existing legislation, without specifying the elements outlined in Article 28(3) of the GDPR (see also Recital 6 of this document). Moreover, the data controller states that during the initial investigation of the incident, the processor did not fully respond to its requests for clarification regarding the incident. Furthermore, the detailed information regarding the incident appears to have been provided by the processor to the data controller in October 2023, approximately three (3) months after the occurrence of the incident. It should be noted, however, that the data controller did not submit any evidence demonstrating the actions it took to obtain the necessary information from the processor as promptly as possible.

13. Regarding the inadequate fulfillment of the terms of Article 28(3) of the GDPR concerning the contract between the data controller and the processor, it is noted that, as explicitly stated in the Guidelines 7/2020 of the European Data Protection Board (EDPB) regarding the concepts of the data controller and processor, "since the Regulation establishes a clear obligation to enter into a written contract, where no other relevant legal act applies, the absence of a contract constitutes a violation of the GDPR. Both the data controller and the processor are responsible for ensuring the conclusion of a contract or other legal act governing the processing." Subject to the provisions of the GDPR, the absence of such a contract can lead to significant legal consequences.

17

According to the provisions of Article 83 of the GDPR, the competent supervisory authority has the ability to impose an administrative fine on both the data controller and the processor, taking into account the circumstances of each specific case. Therefore, the failure to fulfill the terms of Article

28(3) of the GDPR constitutes a violation for both the data controller and the processor, and there may be, at the discretion of the Authority, the imposition of an administrative fine for this violation on both parties.

14. The data controller initially assessed that it was not necessary to notify the data subjects of the incident, in accordance with Article 34 of the GDPR, taking into account the following criteria:

- The application was in a testing phase after the upgrade
- The time period during which the vulnerability was identified was short
- The number of files affected was small
- The data of the files hosted in the specific application is considered to be of a simple nature
- Immediate corrective measures were taken
- The risks arising from the specific incident of breach are characterized as low

As mentioned above in the background of this document, the DPO, after re-evaluating the criteria, made a recommendation to the data controller in July 2023 to inform the affected data subjects. The data controller stated that it received the complete details regarding the data subjects that appeared to be affected by the aforementioned breach in early October, at which point the process of personalized notification of the citizens was initiated, which is ongoing. This claim initially contradicts the initial assessment that, based on the information available to the data controller, the files were of minor significance and therefore did not require notification of the subjects, beyond the fact that this initial assessment was not sufficiently substantiated, considering the type and number of files containing personal data that were breached. Furthermore, the data controller does not mention any relevant action taken during the period from July to October 2023, that is, from the time the DPO recommended notifying the affected individuals until the receipt of the detailed information sent to it by the processor. Given these facts, it appears that the data controller did not timely assess the severity of the incident in order to ensure its effective handling, as the correct assessment was ultimately made almost three (3) months after its occurrence. Moreover, the notification that the data controller ultimately provided, albeit with a delay, to the affected individuals is incorrect, on the one hand because it refers to a cyberattack, while the incident is not related to a cyberattack, which is understood as any malicious action taking place via a computer or network with the aim of modifying, destroying, stealing, intercepting, or unauthorized access to the holder's information, and on the other hand because the personal data that leaked to unknown third parties are not detailed. Additionally, the data controller did not update the details of the incident notification to the Authority, as it was obliged to do.

15. The processor, as stated, does not have an official and documented change management policy to ensure that changes to existing applications do not create security gaps. It was also not established that the data controller had imposed such a requirement on the processor. Furthermore, it appears that the existing informal change process of the processor does not follow the optimal security approach, so that changes, particularly those related to security issues, are carried out in a testing environment before being implemented in the production environment. Moreover, regarding this issue, it does not appear that the data controller had set any specific requirement for the processor.

16. Therefore, based on the above, the Authority finds the following violations:

3 See also Regulation (EU) 2019/881 (Cybersecurity Act) in which the term cyberattack is used in relation to "actors" who carry them out.

19

Data Controller:

- a. Violation of Article 5(1)(f) in conjunction with Article 32(1) of the GDPR regarding the security of processing (see above Recital 11, Recital 12 concerning the ineffective control of the processor by the data controller, as well as Recital 15 regarding the lack of establishment of minimum security requirements by the data controller for the processor).
- b. Violation of Article 25(1) of the GDPR regarding data protection by design, as no measures were taken by design to address various risks concerning personal data (see above Recital 11).
- c. Violation of Article 28(3) of the GDPR regarding the elements that must be included in the contract between the data controller and the processor (see above Recital 12 and Recital 13).
- d. Violation of Article 33(4) of the GDPR as updated information regarding the incident was not provided to the Authority without delay (see above Recital 14).

e. Violation of Article 34(1) and (2) of the GDPR, as the assessment of the severity of the incident was not conducted properly in order to inform the affected individuals without undue delay, while the information ultimately provided was not entirely accurate according to the provisions of those articles (see above Recital 14).

17. Furthermore, based on the above, the Authority finds the following violations for the processor:

a. Violation of Article 32(1) of the GDPR regarding the security of processing (see above Recital 11 and Recital 15).

b. Violation of Article 28(3) of the GDPR regarding the elements that must be included in the contract between the data controller and the processor (see above Recital 12 and Recital 13).

18. Based on the above, the Authority considers that there is a case for exercising its corrective powers under Article 58(2) of the GDPR and imposing measures concerning the identified violations.

19. The Authority further considers that, based on the identified violations, an effective, proportionate, and deterrent administrative fine should be imposed, in accordance with the provisions of Article 58(2)(h) of the GDPR, both on the data controller and on the processor, in accordance with Articles 83 of the GDPR and 39 of Law 4624/2019.

20. Furthermore, the Authority took into account the criteria for determining the fine set out in Article 83(2) of the GDPR, the paragraph 4 of this article applicable to the data controller for the violation of Article 5(1)(f) of the GDPR, and the paragraph 5 of the same Article 83 applicable to the other violations of the data controller and for the violations of the processor, Article 39(1) and (2) of Law 4624/2019 concerning the imposition of administrative sanctions on public sector entities, and the Guidelines 04/2022 of the European Data Protection Board for the calculation of administrative fines under the GDPR, which were approved on 24/5/2023, as well as the factual data of the examined case and in particular the following:

i) The identified violation of Article 5(1)(f) of the GDPR by the data controller falls, according to the provisions of Article 83(5)(b) of the GDPR, within the highest category of the administrative fine grading system ("significant" violations with a maximum amount of €20,000,000).

ii) The activity relates to the main activities of the data controller, as the provision of copies of certificates to citizens falls within the responsibilities of the data controller that are exercised on a daily basis.

iii) The number of data subjects that appears to have been affected cannot be considered small, as it seems that nine hundred (900) data subjects who are users of the services of the data controller were affected.

21

the fact that it was not adequately addressed, resulting in the same incident occurring three (3) times, could potentially affect a larger number of data subjects.

iv)

The processing mainly concerns "simple" personal data, which, however, includes data such as police identities or passports that can easily be used in identity theft incidents (in online, e.g., environments) and, consequently, are considered data whose breach could pose serious risks⁵.

v)

The data controller demonstrated difficulty in cooperating with the Authority, failing to provide the requested information in a timely manner.

vi)

Although the violation did not last long and the data controller immediately ceased the operation of the website, there were multiple erroneous attempts to resume operations with the same security gap, which was not perceived by either the data controller or the processor and therefore could potentially have lasted longer.

vii)

No material harm to the data subjects is evident.

viii)

No previous similar violation has been established by the data controller or the processor.

ix)

The fact that the nature of the company of the processor is small as it is a Limited Partnership.

21. The Authority finds that, based on the established circumstances and the above criteria, the sanctions mentioned in the operative part of the decision are an effective, proportionate, and deterrent measure both for restoring compliance and for punishing the illegal behavior.

5 See also Recital 57 of the Guidelines 4/2022 of the EDPB

22

FOR THESE REASONS

The Authority, taking into account the above:

a) Imposes based on Article 58(2)(h) of the GDPR, an administrative fine on the Municipality of Alimos in the total amount of €10,000, for the violation of Article 5(1)(f) in conjunction with Article 32(1) of Regulation (EU) 2016/679.

b) Imposes based on Article 58(2)(h) of the GDPR, an administrative fine on the Municipality of Alimos in the total amount of €5,000, for the violation of Articles 28(3), 33(4), and 34(1) and (2) of Regulation (EU) 2016/679.

c) Issues based on Article 58(2)(h) of the GDPR, a reprimand to the Municipality of Alimos for the violation of Article 25(1) of Regulation (EU) 2016/679.

d) Imposes based on Article 58(2)(h) of the GDPR, an administrative fine on the company named "TEST INFORMATION SYSTEMS O.E." in the total amount of €5,000, for the violation of Articles 32(1) and 28(3) of Regulation (EU) 2016/679.

The President

The Secretary

Konstantinos Menoudakos

Irini Papageorgopoulou